

Not Yet Implemented CVE Rationale

This file classifies CVEs that do not yet have a first-class Maude scenario/property model in [maude/scenario/cve](#).

The classification was rebuilt from the per-CVE description and advisory/fix context in [maude/docs/cve-analysis/collected-cves.json](#), then cross-checked by subagents against the vendor advisory pages when local rationale was ambiguous or inconsistent.

Vendor advisory sources used for the review:

- OpenSSL: <https://openssl-library.org/news/vulnerabilities/>
- GnuTLS: <https://www.gnutls.org/security-new.html>
- wolfSSL: <https://www.wolfssl.com/docs/security-vulnerabilities/>
- Mbed TLS: <https://mbed-tls.readthedocs.io/en/latest/security-advisories/>

Current Counts

Metric	Count	Notes
Total official CVEs, 2016-2026	286	Unique CVE IDs from the four official advisory sources.
Implemented	19	CVEs with a focused scenario/property model or bounded trigger/state-deviation scenario.
Not yet implemented	267	CVEs classified below.
Category1: RFC5246/8446 CVEs	47	Core TLS 1.2/1.3 handshake, record, key exchange, ticket/resumption, or endpoint-state behavior.
Category2: Non-RFC5246/8446 CVEs	220	DTLS, non-core extensions, PKI/X.509, ticket deployment/cache, APIs, side channels, or implementation details outside core stream TLS.

Decision Rules

- Category1 is used only when the vulnerable behavior is in core stream TLS 1.2 RFC 5246 or TLS 1.3 RFC 8446 behavior.
- Category2 is used when the primary behavior is DTLS, X.509/PKI, CMS/PKCS, non-core TLS extensions, external PSK/ticket deployment, application APIs, resource management, timing outside core TLS, or product/platform implementation details.
- DTLS is always Category2.1, even when the advisory also mentions TLS.
- X.509, ASN.1 certificate parsing, OCSP, CRL, DANE, hostname checks, and path validation are Category2.4 unless the primary bug is core TLS message processing.
- Session tickets are Category1.3 only when the primary trigger is core TLS 1.3 resumption/NewSessionTicket state. RFC5077 tickets, multi-server ticket keys, serialized session cache, and ticket APIs are Category2.3.

- If a CVE has a protocol trigger that is already implemented but an unmodeled crash, memory, timing, or resource impact remains, this file classifies the remaining not-yet-implemented impact.

Reconciliation

Category	Count
Category1.1 RFC5246/8446 large model expansion	0
Category1.2 Detailed key-exchange/record/crypto semantics	16
Category1.3 Ticket	1
Category1.4 Memory/parser/resource/API-only	20
Category1.5 Timing/oracle/side-channel	10
Category2.1 DTLS	10
Category2.2 Other TLS RFC extensions (including ECH,PQC, non-core TLS extension)	11
Category2.3 Ticket	8
Category2.4 X.509/certificate	64
Category2.5 Memory/parser/resource/API-only	66
Category2.6 Timing/side-channel	38
Category2.7 Other implementation details	23
Total	267

Category1: RFC5246/8446 CVEs

Category1.1 RFC5246/8446 large model expansion

No not-yet-implemented CVEs were assigned to this subcategory after the per-CVE review.

Category1.2 Detailed key-exchange/record/crypto semantics

CVE	Source	Description / patch basis	Missing model feature
CVE-2016-0701	OpenSSL	OpenSSL advisory describes DH unsafe-prime/static or reused exponent key recovery; the fix checks q where available and enables single-use DH by default.	DH safe-prime/subgroup validation and private-exponent reuse across handshakes.
CVE-2016-2183	OpenSSL	Because DES (and triple-DES) has only a 64-bit block size, birthday attacks are a real concern. Advisory/fix: If you run an old server that doesn't support any better ciphers than DES or RC4, you should upgrade.	Concrete TLS record block-size and traffic-volume semantics for 3DES/SWEET32.

CVE	Source	Description / patch basis	Missing model feature
CVE-2016-7054	OpenSSL	TLS connections using *-CHACHA20-POLY1305 ciphersuites are susceptible to a DoS attack by corrupting larger payloads.	Concrete record cipher, MAC/tag, nonce, and key-schedule semantics.
CVE-2017-3732	OpenSSL	There is a carry propagating bug in the x86_64 Montgomery squaring procedure.	Concrete DH/FFDH parameter, subgroup, arithmetic, or reuse semantics.
CVE-2017-3736	OpenSSL	There is a carry propagating bug in the x86_64 Montgomery squaring procedure.	Concrete DH/FFDH parameter, subgroup, arithmetic, or reuse semantics.
CVE-2017-3738	OpenSSL	There is an overflow bug in the AVX2 Montgomery multiplication procedure used in exponentiation with 1024-bit moduli. Advisory/fix: The fix will be included in OpenSSL 1.1.0h when it becomes available.	Concrete DH/FFDH parameter, subgroup, arithmetic, or reuse semantics.
CVE-2018-0732	OpenSSL	During key agreement in a TLS handshake using a DH(E) based ciphersuite a malicious server can send a very large prime value to the client.	Concrete DH/FFDH parameter, subgroup, arithmetic, or reuse semantics.
CVE-2019-1551	OpenSSL	There is an overflow bug in the x86_64 Montgomery squaring procedure used in exponentiation with 512-bit moduli.	Concrete DH/FFDH parameter, subgroup, arithmetic, or reuse semantics.
CVE-2021-4160	OpenSSL	There is a carry propagation bug in the MIPS32 and MIPS64 squaring procedure. Advisory/fix: It was addressed in the releases of 1.1.1m and 3.0.1 on the 15th of December 2021, and the release of.	Concrete DH/FFDH parameter, subgroup, arithmetic, or reuse semantics.
CVE-2022-1434	OpenSSL	The OpenSSL 3.0 implementation of the RC4-MD5 ciphersuite incorrectly uses the AAD data as the MAC key.	Concrete record cipher, MAC/tag, nonce, and key-schedule semantics.
CVE-2022-2274	OpenSSL	The OpenSSL 3.0.4 release introduced a serious bug in the RSA implementation for X86_64 CPUs supporting the AVX512IFMA instructions.	Concrete RSA key-exchange/decrypt and primitive semantics.
CVE-2023-4807	OpenSSL	OpenSSL advisory describes Poly1305 register corruption on Windows; TLS ChaCha20-Poly1305 can be affected.	Concrete record cipher, MAC/tag, nonce, and key-schedule semantics.
CVE-2023-6129	OpenSSL	OpenSSL advisory describes Poly1305 register corruption on PowerPC; TLS ChaCha20-Poly1305 can be affected.	Concrete record cipher, MAC/tag, nonce, and key-schedule semantics.

CVE	Source	Description / patch basis	Missing model feature
CVE– 2023– 6937	wolfSSL	wolfSSL prior to 5.6.6 did not check that messages in a single (D)TLS record do not span key boundaries. Advisory/fix: The fix for this issue is located in the following GitHub Pull Request.	TLS record key-boundary and encryption-state semantics.
CVE– 2026– 5260	GnuTLS	GnuTLS advisory: short RSA premaster secret with PKCS#11-backed RSA key causes heap over-read; fix is in the GnuTLS upgrade advisory.	Concrete RSA ClientKeyExchange premaster-secret length and token-backed decrypt buffers.
CVE– 2026– 5446	wolfSSL	wolfSSL advisory: ARIA-GCM nonce reuse occurs in TLS 1.2 record encryption.	Concrete TLS record nonce construction and ARIA-GCM AEAD semantics.

Category1.3 Ticket

CVE	Source	Description / patch basis	Missing model feature
CVE– 2022– 39173	wolfSSL	wolfSSL advisory: malformed TLS 1.3 session-ticket resumption path can crash a server.	Core TLS 1.3 NewSessionTicket/resumption parser state plus concrete crash impact.

Category1.4 Memory/parser/resource/API-only

CVE	Source	Description / patch basis	Missing model feature
CVE– 2016– 6305	OpenSSL	OpenSSL 1.1.0 SSL/TLS will hang during a call to SSL_peek() if the peer sends an empty record.	Concrete TLS parser buffers, message lengths, nullability, object lifetime, or API/resource state.
CVE– 2016– 6306	OpenSSL	In OpenSSL 1.0.2 and earlier some missing message length checks can result in OOB reads of up to 2 bytes beyond an allocated buffer.	Concrete TLS parser buffers, message lengths, nullability, object lifetime, or API/resource state.
CVE– 2016– 6307	OpenSSL	A TLS message includes 3 bytes for its length in the header for the message.	Concrete TLS parser buffers, message lengths, nullability, object lifetime, or API/resource state.

CVE	Source	Description / patch basis	Missing model feature
CVE– 2016– 6309	OpenSSL	OpenSSL advisory describes a TLS large-message realloc path that leaves a dangling pointer and can corrupt memory.	Concrete TLS parser buffers, message lengths, nullability, object lifetime, or API/resource state.
CVE– 2017– 3730	OpenSSL	If a malicious server supplies bad parameters for a DHE or ECDHE key exchange then this can result in the client attempting to dereference a NULL pointer leading to.	Concrete TLS parser buffers, message lengths, nullability, object lifetime, or API/resource state.
CVE– 2017– 3731	OpenSSL	If an SSL/TLS server or client is running on a 32-bit host, and a specific cipher is being used, then a truncated packet can cause that server or client to perform. Advisory/fix: For OpenSSL 1.1.0, the crash can be triggered when using CHACHA20/POLY1305; users should upgrade to.	Concrete TLS parser buffers, message lengths, nullability, object lifetime, or API/resource state.
CVE– 2017– 3737	OpenSSL	OpenSSL advisory describes TLS error-state bypass via SSL_read/SSL_write after a failed handshake.	Concrete TLS parser buffers, message lengths, nullability, object lifetime, or API/resource state.
CVE– 2019– 3836	GnuTLS	CVE record/advisory separates this as TLS 1.3 post-handshake/asynchronous message uninitialized pointer access.	Concrete TLS parser buffers, message lengths, nullability, object lifetime, or API/resource state.
CVE– 2019– 11873	wolfSSL	In wolfSSL version 4.0.0, there is a potential buffer overflow case with the TLSv1.3 PSK extension parsing.	Concrete TLS parser buffers, message lengths, nullability, object lifetime, or API/resource state.
CVE– 2020– 1967	OpenSSL	OpenSSL advisory describes TLS 1.3 signature_algorithms_cert plus SSL_check_chain null dereference.	Concrete TLS parser buffers, message lengths, nullability, object lifetime, or API/resource state.
CVE– 2020– 12457	wolfSSL	In wolfSSL versions prior to 4.5.0, a denial of service attack on TLS 1.3 servers from repetitively sending ChangeCipherSpecs messages is possible.	Concrete TLS parser buffers, message lengths, nullability,

CVE	Source	Description / patch basis	Missing model feature
			object lifetime, or API/resource state.
CVE– 2020– 24659	GnuTLS	Severity Moderate; null-pointer dereference It was found by oss-fuzz that the server sending a "no_renegotiation" alert in an unexpected timing, followed by an. Advisory/fix: Recommendation: To address the issue found upgrade to GnuTLS 3.6.15 or later versions.	Concrete TLS parser buffers, message lengths, nullability, object lifetime, or API/resource state.
CVE– 2021– 3449	OpenSSL	An OpenSSL TLS server may crash if sent a maliciously crafted renegotiation ClientHello message from a client. Advisory/fix: Users of these versions should upgrade to OpenSSL 1.1.1k.	Concrete TLS parser buffers, message lengths, nullability, object lifetime, or API/resource state.
CVE– 2021– 20231	GnuTLS	Severity Low; use-after-free It was found that the client sending a "key_share" or "pre_share_key" extension may result in dereferencing a pointer no longer. Advisory/fix: Recommendation: To address the issue found upgrade to GnuTLS 3.7.1 or later versions.	Concrete TLS parser buffers, message lengths, nullability, object lifetime, or API/resource state.
CVE– 2021– 20232	GnuTLS	Severity Low; use-after-free It was found that the client sending a "key_share" or "pre_share_key" extension may result in dereferencing a pointer no longer. Advisory/fix: Recommendation: To address the issue found upgrade to GnuTLS 3.7.1 or later versions.	Concrete TLS parser buffers, message lengths, nullability, object lifetime, or API/resource state.
CVE– 2022– 42905	wolfSSL	In the case that the WOLFSSL_CALLBACKS macro is set when building wolfSSL, there is a potential heap over read of 5 bytes when handling TLS 1.3 client connections.	Concrete TLS parser buffers, message lengths, nullability, object lifetime, or API/resource state.
CVE– 2023– 6936	wolfSSL	A potential heap overflow read is possible in servers connecting over TLS 1.3 when the optional WOLFSSL_CALLBACKS has been defined. Advisory/fix: The fix for this issue is located in the following GitHub Pull Request.	Concrete TLS parser buffers, message lengths, nullability, object lifetime, or API/resource state.
CVE– 2024– 0901	wolfSSL	wolfSSL advisory/patch describes a TLS 1.3 padding/bounds DoS and out-of-bounds read.	Concrete TLS parser buffers, message lengths, nullability, object lifetime, or API/resource state.
CVE– 2024–	OpenSSL	Issue summary: Calling the OpenSSL API function SSL_free_buffers may cause memory to be accessed	Concrete TLS parser buffers, message

CVE	Source	Description / patch basis	Missing model feature
4741		that was previously freed in some situations Impact summary: A use.	lengths, nullability, object lifetime, or API/resource state.
CVE– 2026– 5778	wolfSSL	wolfSSL advisory: malformed TLS 1.2 AEAD record in sniffer path causes length underflow.	Concrete TLS parser buffers, message lengths, nullability, object lifetime, or API/resource state.

Category1.5 Timing/oracle/side-channel

CVE	Source	Description / patch basis	Missing model feature
CVE– 2016– 2107	OpenSSL	A MITM attacker can use a padding oracle attack to decrypt traffic when the connection uses an AES CBC cipher and the server support AES-NI. Advisory/fix: This issue was introduced as part of the fix for Lucky 13 padding attack (a related CVE).	Attacker-visible timing, oracle, repeated-query, or cost observations for core TLS behavior.
CVE– 2017– 13099	wolfSSL	Versions of wolfSSL up to 3.12.2 have a weak Bleichenbacher vulnerability with suites that use an RSA-encrypted premaster secret.	Attacker-visible timing, oracle, repeated-query, or cost observations for core TLS behavior.
CVE– 2018– 16870	wolfSSL	Versions of wolfSSL prior to 3.15.7 are vulnerable to a new variant of the Bleichenbacher attack to perform downgrade attacks against TLS, which may lead to leakage.	Attacker-visible timing, oracle, repeated-query, or cost observations for core TLS behavior.
CVE– 2019– 1559	OpenSSL	If an application encounters a fatal protocol error and then calls SSL_shutdown() twice (once to send a close_notify, and once to receive one) then OpenSSL can.	Attacker-visible timing, oracle, repeated-query, or cost observations for core TLS behavior.
CVE– 2020– 1968	OpenSSL	The Raccoon attack exploits a flaw in the TLS specification which can lead to an attacker being able to compute the pre-master secret in connections which have used.	Attacker-visible timing, oracle, repeated-query, or cost observations for core TLS behavior.
CVE– 2022–	OpenSSL	A timing based side channel exists in the OpenSSL RSA Decryption implementation which could be	Attacker-visible timing, oracle, repeated-

CVE	Source	Description / patch basis	Missing model feature
4304		sufficient to recover a plaintext across a network in a.	query, or cost observations for core TLS behavior.
CVE–2023–0361	GnuTLS	Severity Medium; timing sidechannel in RSA decryption A vulnerability was found that the response times to malformed RSA ciphertexts in ClientKeyExchange differ. Advisory/fix: Recommendation: To address the issue found upgrade to GnuTLS 3.8.0 or later versions.	Attacker-visible timing, oracle, repeated-query, or cost observations for core TLS behavior.
CVE–2023–6935	wolfSSL	wolfSSL advisory describes the Marvin RSA timing issue affecting saved TLS connections.	Attacker-visible timing, oracle, repeated-query, or cost observations for core TLS behavior.
CVE–2024–13176	OpenSSL	Issue summary: A timing side-channel which could potentially allow recovering the private key exists in the ECDSA signature computation.	Attacker-visible timing, oracle, repeated-query, or cost observations for core TLS behavior.
CVE–2025–11932	wolfSSL	wolfSSL advisory: TLS 1.3 PSK binder verification was not constant-time.	Timing observation model for TLS 1.3 PSK binder comparison.

Category2: Non-RFC5246/8446 CVEs

Category2.1 DTLS

CVE	Source	Description / patch basis	Missing model feature
CVE–2016–2179	OpenSSL	In a DTLS connection where handshake messages are delivered out-of-order those messages that OpenSSL is not yet ready to process will be buffered for later use.	DTLS datagram transport: epochs, sequence numbers, replay, fragments, reassembly, or ACK/cookie state.
CVE–2016–2181	OpenSSL	A flaw in the DTLS replay attack protection mechanism means that records that arrive for future epochs update the replay protection "window" before the MAC for the.	DTLS datagram transport: epochs, sequence numbers, replay, fragments, reassembly, or ACK/cookie state.

CVE	Source	Description / patch basis	Missing model feature
CVE-2016-6308	OpenSSL	A DTLS message includes 3 bytes for its length in the header for the message.	DTLS datagram transport: epochs, sequence numbers, replay, fragments, reassembly, or ACK/cookie state.
CVE-2020-11501	GnuTLS	Severity High; flaw in DTLS protocol implementation It was found that GnuTLS 3.6.3 introduced a regression in the DTLS protocol implementation. Advisory/fix: Recommendation: To address the issue found upgrade to GnuTLS 3.6.13 or later versions.	DTLS datagram transport: epochs, sequence numbers, replay, fragments, reassembly, or ACK/cookie state.
CVE-2022-23408	wolfSSL	wolfSSL advisory includes DTLS scope for CBC/DES3 IV generation, so this is placed in DTLS despite a TLS facet.	DTLS datagram transport: epochs, sequence numbers, replay, fragments, reassembly, or ACK/cookie state.
CVE-2022-34293	wolfSSL	Potential for DTLS DoS attack.	DTLS datagram transport: epochs, sequence numbers, replay, fragments, reassembly, or ACK/cookie state.
CVE-2026-5264	wolfSSL	Heap buffer overflow in DTLS 1.3 ACK message processing.	DTLS datagram transport: epochs, sequence numbers, replay, fragments, reassembly, or ACK/cookie state.
CVE-2026-33845	GnuTLS	Severity High; heap overrun A remotely triggerable underflow in the DTLS reassembly code led to a heap overrun. Advisory/fix: Recommendation: To address the issue found, upgrade to GnuTLS 3.8.13 or later versions.	DTLS datagram transport: epochs, sequence numbers, replay, fragments, reassembly, or ACK/cookie state.

CVE	Source	Description / patch basis	Missing model feature
CVE-2026-33846	GnuTLS	Severity High; heap overwrite GnuTLS didn't check that DTLS fragments claimed a consistent message_length value. Advisory/fix: Recommendation: To address the issue found, upgrade to GnuTLS 3.8.13 or later versions.	DTLS datagram transport: epochs, sequence numbers, replay, fragments, reassembly, or ACK/cookie state.
CVE-2026-42009	GnuTLS	Severity High; undefined behaviour The comparator function used for ordering DTLS packets by sequence numbers did not follow qsort comparator contracts in case. Advisory/fix: Recommendation: To address the issue found, upgrade to GnuTLS 3.8.13 or later versions.	DTLS datagram transport: epochs, sequence numbers, replay, fragments, reassembly, or ACK/cookie state.

Category2.2 Other TLS RFC extensions (including ECH,PQC, non-core TLS extension)

CVE	Source	Description / patch basis	Missing model feature
CVE-2017-3733	OpenSSL	During a renegotiation handshake if the Encrypt-Then-Mac extension is negotiated where it was not in the original handshake (or vice-versa) then this can cause.	Non-core TLS extension datatype, negotiation state, byte parser, or extension-specific resource semantics.
CVE-2024-5535	OpenSSL	Issue summary: Calling the OpenSSL API function SSL_select_next_proto with an empty supported client protocols buffer may cause a crash or memory contents to be. Advisory/fix: The fix will be included in the next releases when they become available.	Non-core TLS extension datatype, negotiation state, byte parser, or extension-specific resource semantics.
CVE-2024-12797	OpenSSL	Issue summary: Clients using RFC7250 Raw Public Keys (RPKs) to authenticate a server may fail to notice that the server was not authenticated, because handshakes.	Non-core TLS extension datatype, negotiation state, byte parser, or extension-specific resource semantics.
CVE-2025-66199	OpenSSL	Issue summary: A TLS 1.3 connection using certificate compression can be forced to allocate a large buffer before decompression without checking against the.	Non-core TLS extension datatype, negotiation state, byte parser, or extension-specific resource semantics.

CVE	Source	Description / patch basis	Missing model feature
CVE– 2026– 2673	OpenSSL	Issue summary: An OpenSSL TLS 1.3 server may fail to negotiate the expected preferred key exchange group when its key exchange group configuration includes the. Advisory/fix: OpenSSL 3.6 users should upgrade to OpenSSL 3.6.2 once it is released.	Non-core TLS extension datatype, negotiation state, byte parser, or extension-specific resource semantics.
CVE– 2026– 3547	wolfSSL	Out-of-bounds read in ALPN parsing due to incomplete validation.	Non-core TLS extension datatype, negotiation state, byte parser, or extension-specific resource semantics.
CVE– 2026– 3549	wolfSSL	Heap Overflow in TLS 1.3 ECH parsing.	Non-core TLS extension datatype, negotiation state, byte parser, or extension-specific resource semantics.
CVE– 2026– 3849	wolfSSL	Stack Buffer Overflow in wc_HpkeLabeledExtract via oversized ECH config.	Non-core TLS extension datatype, negotiation state, byte parser, or extension-specific resource semantics.
CVE– 2026– 5393	wolfSSL	Dual-Algorithm CertificateVerify out-of-bounds read. Advisory/fix: Thanks to Sunwoo Lee, Woohyun Choi, and Seunghyun Yoon (Korea Institute of Energy Technology, KENTECH).	Non-core TLS extension datatype, negotiation state, byte parser, or extension-specific resource semantics.
CVE– 2026– 5460	wolfSSL	When a malicious TLS 1.3 server sends a ServerHello with a truncated PQC hybrid KeyShare (e.g., P256_ML_KEM_512 with 10 bytes instead of the required 768+), the.	Non-core TLS extension datatype, negotiation state, byte parser, or extension-specific resource semantics.
CVE– 2026– 5503	wolfSSL	In TLSX_EchChangeSNI, the ctx->extensions branch set extensions unconditionally even when TLSX_Find returned NULL.	Non-core TLS extension datatype, negotiation state, byte parser, or extension-

CVE	Source	Description / patch basis	Missing model feature
			specific resource semantics.
Category2.3 Ticket			
CVE	Source	Description / patch basis	Missing model feature
CVE– 2016– 6302	OpenSSL	If a server uses SHA512 for TLS session ticket HMAC it is vulnerable to a DoS attack where a malformed ticket will result in an OOB read which will ultimately crash.	Session-ticket/session-cache/external-PSK deployment state, serialized storage, identity, or key management.
CVE– 2020– 13777	GnuTLS	Severity High; flaw in TLS session ticket key construction It was found that GnuTLS 3.6.4 introduced a regression in the TLS protocol implementation. Advisory/fix: Recommendation: To address the issue found upgrade to GnuTLS 3.6.14 or later versions.	Multi-server ticket-key deployment, issuer/key identity, and cross-server ticket cache.
CVE– 2022– 38153	wolfSSL	In wolfSSL version 5.3.0 if compiled with --enable-session-ticket and the client has non-empty session cache, with TLS 1.2 there is the possibility of a man in the.	Session-ticket/session-cache/external-PSK deployment state, serialized storage, identity, or key management.
CVE– 2024– 2511	OpenSSL	Issue summary: Some non-default TLS server configurations can cause unbounded memory growth when processing TLSv1.3 sessions Impact summary: An attacker may exploit.	Session-ticket/session-cache/external-PSK deployment state, serialized storage, identity, or key management.
CVE– 2026– 2646	wolfSSL	A heap-buffer-overflow vulnerability exists in wolfSSL's wolfSSL_d2i_SSL_SESSION() function.	Session-ticket/session-cache/external-PSK deployment state, serialized storage, identity, or key management.
CVE– 2026– 5507	wolfSSL	When restoring a session from cache, a pointer from the serialized session data is used in a free operation without validation.	Session-ticket/session-cache/external-PSK deployment state, serialized storage,

CVE	Source	Description / patch basis	Missing model feature
			identity, or key management.
CVE– 2026– 34877	Mbed TLS	Mbed TLS advisory: serialized TLS session/context data lacks built-in integrity/confidentiality protection.	Serialized session/context protection, cache storage, and deserialization invariants.
CVE– 2026– 42010	GnuTLS	GnuTLS advisory: RSA-PSK usernames with embedded NUL matched truncated names; fix is in the GnuTLS upgrade advisory.	External PSK provisioning plus identity string equality with embedded NUL handling.

Category2.4 X.509/certificate

CVE	Source	Description / patch basis	Missing model feature
CVE– 2016– 2176	OpenSSL	ASN1 Strings that are over 1024 bytes can cause an overread in applications using the X509_NAME_oneline() function on EBCDIC systems.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE– 2016– 6304	OpenSSL	A malicious client can send an excessively large OCSP Status Request extension.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE– 2016– 7052	OpenSSL	This issue only affects OpenSSL 1.0.2i, released on 22nd September 2016. Advisory/fix: A bug fix which included a CRL sanity check was added to OpenSSL 1.1.0 but was omitted from OpenSSL.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE– 2017– 2800	wolfSSL	Versions of wolfSSL before 3.11.0 have a possible out-of-bounds write by one from a crafted certificate being passed to the function.	X.509/ASN.1 certificate, OCSP/CRL,

CVE	Source	Description / patch basis	Missing model feature
			DANE, hostname, or path-validation semantics.
CVE-2017-3735	OpenSSL	While parsing an IPAddressFamily extension in an X.509 certificate, it is possible to do a one-byte overread.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE-2017-5334	GnuTLS	Official GnuTLS advisory: X.509 Proxy Certificate Information extension double-free; fixed by upgrading per advisory.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE-2017-5335	GnuTLS	Official GnuTLS advisory: OpenPGP certificate decoder heap/stack overflow; fixed by upgrading per advisory.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE-2017-5336	GnuTLS	Official GnuTLS advisory: OpenPGP certificate decoder heap/stack overflow; fixed by upgrading per advisory.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE-2017-5337	GnuTLS	Official GnuTLS advisory: OpenPGP certificate decoder heap/stack overflow; fixed by upgrading per advisory.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE-2017-	GnuTLS	Official GnuTLS advisory: status_response/OCSP-stapling decode null dereference; fixed by upgrading per advisory.	X.509/ASN.1 certificate,

CVE	Source	Description / patch basis	Missing model feature
7507			OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE– 2019– 3829	GnuTLS	CVE record/advisory separates this from the paired local text as certificate verification API double-free.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE– 2019– 15651	wolfSSL	wolfSSL 4.1.0 has a one-byte heap-based buffer over-read in DecodeCertExtensions in wolfcrypt/src/asn.c because reading the ASN_BOOLEAN byte is mishandled for a.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE– 2019– 16748	wolfSSL	In wolfSSL through 4.1.0, there is a missing sanity check of memory accesses in parsing ASN.1 certificate data while handshaking.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE– 2019– 18840	wolfSSL	In wolfSSL 4.1.0 through 4.2.0c, there are missing sanity checks of memory accesses in parsing ASN.1 certificate data while handshaking.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE– 2020– 1971	OpenSSL	The X.509 GeneralName type is a generic type for representing different types of names.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.

CVE	Source	Description / patch basis	Missing model feature
CVE– 2021– 3450	OpenSSL	The X509_V_FLAG_X509_STRICT flag enables additional security checks of the certificates present in a certificate chain. Advisory/fix: Users of these versions should upgrade to OpenSSL 1.1.1k.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE– 2021– 3712	OpenSSL	ASN.1 strings are represented internally within OpenSSL as an ASN1_STRING structure which contains a buffer holding the string data and a field holding the buffer.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE– 2021– 4044	OpenSSL	Internally libssl in OpenSSL calls X509_verify_cert() on the client side to verify a certificate supplied by a server.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE– 2021– 23841	OpenSSL	The OpenSSL public API function X509_issuer_and_serial_hash() attempts to create a unique hash value based on the issuer and serial number data contained within an. Advisory/fix: Users of these versions should upgrade to OpenSSL 1.1.1j.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE– 2021– 38597	wolfSSL	OCSP verification issue when response is for a certificate with no relation to the chain in question BUT that response contains the NoCheck extension which. Advisory/fix: Users who should upgrade to 4.8.1 are TLS client users doing OCSP, TLS server users doing mutual auth.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE– 2022– 0778	OpenSSL	The BN_mod_sqrt() function, which computes a modular square root, contains a bug that can cause it to loop forever for non-prime moduli. Advisory/fix: It was addressed in the releases of 1.1.1n and 3.0.2 on the 15th March 2022.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or

CVE	Source	Description / patch basis	Missing model feature
			path-validation semantics.
CVE– 2022– 1343	OpenSSL	The function OCSP_basic_verify verifies the signer certificate on an OCSP response.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE– 2022– 1473	OpenSSL	The OPENSSL_LH_flush() function, which empties a hash table, contains a bug that breaks reuse of the memory occupied by the removed hash table entries.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE– 2022– 2509	GnuTLS	Severity Medium; memory corruption When gnutls_pkcs7_verify cannot verify signature against given trust list, it starts creating a chain of certificates starting. Advisory/fix: Recommendation: To address the issue found upgrade to GnuTLS 3.7.7 or later versions.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE– 2022– 3602	OpenSSL	A buffer overrun can be triggered in X.509 certificate verification, specifically in name constraint checking. Advisory/fix: Users are still encouraged to upgrade to a new version as soon as possible.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE– 2022– 3786	OpenSSL	A buffer overrun can be triggered in X.509 certificate verification, specifically in name constraint checking.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE– 2022– 3996	OpenSSL	If an X.509 certificate contains a malformed policy constraint and policy processing is enabled, then a write lock will be taken twice recursively.	X.509/ASN.1 certificate, OCSP/CRL, DANE,

CVE	Source	Description / patch basis	Missing model feature
			hostname, or path-validation semantics.
CVE-2022-4203	OpenSSL	A read buffer overrun can be triggered in X.509 certificate verification, specifically in name constraint checking.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE-2023-0286	OpenSSL	There is a type confusion vulnerability relating to X.400 address processing inside an X.509 GeneralName.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE-2023-0464	OpenSSL	A security vulnerability has been identified in all supported versions of OpenSSL related to the verification of X.509 certificate chains that include policy.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE-2023-0465	OpenSSL	Applications that use a non-default option when verifying certificates may be vulnerable to an attack from a malicious CA to circumvent certain checks.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE-2023-0466	OpenSSL	The function X509_VERIFY_PARAM_add0_policy() is documented to implicitly enable the certificate policy check when doing certificate verification.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE-2023-2650	OpenSSL	Issue summary: Processing some specially crafted ASN.1 object identifiers or data containing them may be very slow.	X.509/ASN.1 certificate, OCSP/CRL,

CVE	Source	Description / patch basis	Missing model feature
			DANE, hostname, or path-validation semantics.
CVE– 2024– 0567	GnuTLS	Severity Medium; Denial of service When validating a certificate chain which contains a cycle of cross-signed signatures of multiple CA certificates, GnuTLS. Advisory/fix: Recommendation: To address the issue found upgrade to GnuTLS 3.8.3 or later versions.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE– 2024– 5991	wolfSSL	In the function MatchDomainName(), input param str is treated as a NULL terminated string despite being user provided and unchecked. Advisory/fix: Fixed in github pull request #7604	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE– 2024– 6119	OpenSSL	Issue summary: Applications performing certificate name checks (e.g., TLS clients checking server certificates) may attempt to read an invalid memory address.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE– 2024– 12243	GnuTLS	Severity Medium; Denial of service When a certificate contains a number of Name Constraints extensions, GnuTLS applications can take excessive amount of time to. Advisory/fix: Recommendation: To address the issue found upgrade to GnuTLS 3.8.9 or later versions.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE– 2024– 28835	GnuTLS	Severity Medium; Denial of service When validating a certificate chain with more then 16 certificates GnuTLS applications crash with an assertion failure. Advisory/fix: Recommendation: To address the issue found upgrade to GnuTLS 3.8.4 or later versions.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE– 2025–	OpenSSL	Issue summary: Use of -adtreject option with the openssl x509 application adds a trusted use instead of a rejected	X.509/ASN.1 certificate,

CVE	Source	Description / patch basis	Missing model feature
4575		use for a certificate.	OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE– 2025– 7395	wolfSSL	When using WOLFSSL_SYS_CA_CERTS and WOLFSSL_APPLE_NATIVE_CERT_VALIDATION on an Apple platform, the native trust store verification routine overrides errors produced.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE– 2025– 14831	GnuTLS	Severity Medium; denial of service Verifying certificates with pathological amounts of name constraints could lead to a denial of service attack via resource. Advisory/fix: Recommendation: To address the issue found, upgrade to GnuTLS 3.8.12 or later versions.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE– 2025– 32988	GnuTLS	Severity Low; Memory corruption on error path When any error occurs during exporting a certificate with an otherName in the SAN (subject alternative name). Advisory/fix: Recommendation: To address the issue found upgrade to GnuTLS 3.8.10 or later versions.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE– 2025– 32989	GnuTLS	Severity Medium; Heap read buffer overflow When an X.509 certificate contains an SCT (signed certificate timestamp) extension and its length field is malformed. Advisory/fix: Recommendation: To address the issue found upgrade to GnuTLS 3.8.10 or later versions.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE– 2025– 69420	OpenSSL	Issue summary: A type confusion vulnerability exists in the TimeStamp Response verification code where an ASN1_TYPE union member is accessed without first.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.

CVE	Source	Description / patch basis	Missing model feature
CVE– 2026– 3229	wolfSSL	Integer Overflow in Certificate Chain Allocation.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE– 2026– 3548	wolfSSL	Two buffer overflow vulnerabilities existed in the wolfSSL CRL parser when parsing CRL numbers: a heap-based buffer overflow could occur when improperly storing the.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE– 2026– 3832	GnuTLS	Severity Low; revocation bypass When validating a certificate against a multi-entry OCSP response, the revocation status was always checked for the first entry. Advisory/fix: Recommendation: To address the issue found, upgrade to GnuTLS 3.8.13 or later versions.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE– 2026– 3833	GnuTLS	Severity Moderate; name constraint bypass Domain name comparison during name constraints processing was case-sensitive, violating RFC 5280 section 7.2. Advisory/fix: Recommendation: To address the issue found, upgrade to GnuTLS 3.8.13 or later versions.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE– 2026– 5187	wolfSSL	Heap out-of-bounds write in DecodeObjectId() caused by an off-by-one bounds check combined with a sizeof mismatch.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE– 2026– 5188	wolfSSL	An integer underflow issue exists in wolfSSL when parsing the Subject Alternative Name (SAN) extension of X.509 certificates.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or

CVE	Source	Description / patch basis	Missing model feature
			path-validation semantics.
CVE– 2026– 5194	wolfSSL	Missing hash/digest size and OID checks allow digests smaller than allowed by FIPS 186-4 or 186-5 (as appropriate), or smaller than is appropriate for the relevant.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE– 2026– 5263	wolfSSL	URI nameConstraints from constrained intermediate CAs are parsed but not enforced during certificate chain verification in wolfcrypt/src/asn.c.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE– 2026– 5447	wolfSSL	Heap buffer overflow in CertFromX509 via AuthorityKeyIdentifier size confusion.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE– 2026– 5448	wolfSSL	X.509 date buffer overflow in wolfSSL_X509_notAfter / wolfSSL_X509_notBefore.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE– 2026– 5501	wolfSSL	wolfSSL_X509_verify_cert() in the OpenSSL compatibility layer accepts a certificate chain in which the leaf's signature is not checked, if the attacker supplies.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE– 2026– 5772	wolfSSL	A 1-byte stack buffer over-read exists in the MatchDomainName function in src/internal.c when processing wildcard patterns with the LEFT_MOST_WILDCARD_ONLY flag.	X.509/ASN.1 certificate, OCSP/CRL, DANE,

CVE	Source	Description / patch basis	Missing model feature
			hostname, or path-validation semantics.
CVE– 2026– 25833	Mbed TLS	Mbed TLS advisory: x509_inet_pton_ipv6 buffer underflow in X.509 IP parsing helper.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE– 2026– 28387	OpenSSL	Issue summary: An uncommon configuration of clients performing DANE TLSA-based server authentication, when paired with uncommon server DANE TLSA records, may result.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE– 2026– 28388	OpenSSL	Issue summary: When a delta CRL that contains a Delta CRL Indicator extension is processed a NULL pointer dereference might happen if the required CRL Number.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE– 2026– 31789	OpenSSL	Issue summary: Converting an excessively large OCTET STRING value to a hexadecimal string leads to a heap buffer overflow on 32 bit platforms.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE– 2026– 34874	Mbed TLS	Mbed TLS advisory: allocation-failure path in distinguished-name/X.509 writer functions can null-deref.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE– 2026– 42011	GnuTLS	Severity Medium; name constraint bypass Permitted name constraints were wrongfully ignored when prior CAs only had excluded name constraints, resulting in a name.	X.509/ASN.1 certificate, OCSP/CRL,

CVE	Source	Description / patch basis	Missing model feature
		Advisory/fix: Recommendation: To address the issue found, upgrade to GnuTLS 3.8.13 or later versions.	DANE, hostname, or path-validation semantics.
CVE– 2026– 42012	GnuTLS	Severity Medium; certificate misuse Certificates containing URI or SRV Subject Alternative Names would fall back to checking DNS hostnames against Common Name. Advisory/fix: Recommendation: To address the issue found, upgrade to GnuTLS 3.8.13 or later versions.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.
CVE– 2026– 42013	GnuTLS	Severity Medium; certificate misuse Validation of certificates with oversized Subject Alternative Names would fall back to checking DNS hostnames against Common. Advisory/fix: Recommendation: To address the issue found, upgrade to GnuTLS 3.8.13 or later versions.	X.509/ASN.1 certificate, OCSP/CRL, DANE, hostname, or path-validation semantics.

Category2.5 Memory/parser/resource/API-only

CVE	Source	Description / patch basis	Missing model feature
CVE– 2016– 0705	OpenSSL	A double free bug was discovered when OpenSSL parses malformed DSA private keys and could lead to a DoS attack or memory corruption for applications that receive.	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2016– 0797	OpenSSL	In the BN_hex2bn function the number of hex digits is calculated using an int value i .	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2016–	OpenSSL	The SRP user database lookup method SRP_VBASE_get_by_user had confusing memory	Concrete memory, parser,

CVE	Source	Description / patch basis	Missing model feature
0798		management semantics; the returned pointer was sometimes newly allocated, and.	serialized object, resource, or application API semantics outside core TLS.
CVE– 2016– 0799	OpenSSL	The internal fmtstr function used in processing a "%s" format string in the BIO_*printf functions could overflow while calculating the length of a string and.	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2016– 2105	OpenSSL	An overflow can occur in the EVP_EncodeUpdate() function which is used for Base64 encoding of binary data. Advisory/fix: (Note: Initial analysis suggested that the PEM_write_bio* were vulnerable, and this is reflected in the.	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2016– 2106	OpenSSL	An overflow can occur in the EVP_EncryptUpdate() function.	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2016– 2108	OpenSSL	This issue affected versions of OpenSSL prior to April 2015. Advisory/fix: The bug causing the vulnerability was fixed on April 18th 2015, and released as part of the June 11th.	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2016– 2109	OpenSSL	When ASN.1 data is read from a BIO using functions such as d2i_CMS_bio() a short invalid encoding can casuse allocation of large amounts of memory potentially.	Concrete memory, parser, serialized object,

CVE	Source	Description / patch basis	Missing model feature
			resource, or application API semantics outside core TLS.
CVE– 2016– 2177	OpenSSL	Avoid some undefined pointer arithmetic A common idiom in the codebase is to check limits in the following manner: "p + len > limit" Where "p" points to some.	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2016– 2180	OpenSSL	The function TS_OBJ_print_bio() misuses OBJ_obj2txt(): the return value is the total length the OID text representation would use and not the amount of data written.	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2016– 2182	OpenSSL	The function BN_bn2dec() does not check the return value of BN_div_word().	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2016– 6303	OpenSSL	An overflow can occur in MDC2_Update() either if called directly or through the EVP_DigestUpdate() function using MDC2.	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2016– 7053	OpenSSL	Applications parsing invalid CMS structures can crash with a NULL pointer dereference.	Concrete memory, parser, serialized object, resource, or

CVE	Source	Description / patch basis	Missing model feature
			application API semantics outside core TLS.
CVE– 2017– 8854	wolfSSL	Versions of wolfSSL before 3.10.2 have a possible out-of-bounds memory access when loading crafted DH parameters.	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2018– 0739	OpenSSL	Constructed ASN.1 types with a recursive definition (such as can be found in PKCS7) could eventually exceed the stack given malicious input with excessive recursion.	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2020– 36177	wolfSSL	RsaPad_PSS in wolfcrypt/src/rsa.c in wolfSSL before 4.6.0 has an out-of-bounds write for certain relationships between key size and digest size.	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2021– 3711	OpenSSL	In order to decrypt SM2 encrypted data an application is expected to call the API function EVP_PKEY_decrypt().	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2021– 23840	OpenSSL	Calls to EVP_CipherUpdate, EVP_EncryptUpdate and EVP_DecryptUpdate may overflow the output length argument in some cases where the input length is close to the. Advisory/fix: Users of these versions should upgrade to OpenSSL 1.1.1j.	Concrete memory, parser, serialized object, resource, or application API

CVE	Source	Description / patch basis	Missing model feature
			semantics outside core TLS.
CVE– 2022– 2097	OpenSSL	OpenSSL description says the affected OCB mode is not used by TLS/DTLS; issue is low-level OCB API.	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2022– 3358	OpenSSL	OpenSSL supports creating a custom cipher via the legacy EVP_CIPHER_meth_new() function and associated function calls.	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2022– 4450	OpenSSL	The function PEM_read_bio_ex() reads a PEM file from a BIO and parses and decodes the "name" (e.g.	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2022– 38152	wolfSSL	If using wolfSSL_clear to reset a WOLFSSL object (vs the normal wolfSSL_free/wolfSSL_new) it can result in runtime issues.	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2023– 0215	OpenSSL	The public API function BIO_new_NDEF is a helper function used for streaming ASN.1 data via a BIO.	Concrete memory, parser, serialized object, resource, or application API semantics

CVE	Source	Description / patch basis	Missing model feature
			outside core TLS.
CVE– 2023– 0216	OpenSSL	An invalid pointer dereference on read can be triggered when an application tries to load malformed PKCS7 data with the <code>d2i_PKCS7()</code> , <code>d2i_PKCS7_bio()</code> or.	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2023– 0217	OpenSSL	An invalid pointer dereference on read can be triggered when an application tries to check a malformed DSA public key by the <code>EVP_PKEY_public_check()</code> function.	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2023– 0401	OpenSSL	A NULL pointer can be dereferenced when signatures are being verified on PKCS7 signed or signedAndEnveloped data.	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2023– 1255	OpenSSL	Issue summary: The AES-XTS cipher decryption implementation for 64 bit ARM platform contains a bug that could cause it to read past the input buffer, leading to a.	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2023– 2975	OpenSSL	Issue summary: The AES-SIV cipher implementation contains a bug that causes it to ignore empty associated data entries which are unauthenticated as a consequence.	Concrete memory, parser, serialized object, resource, or application API semantics

CVE	Source	Description / patch basis	Missing model feature
			outside core TLS.
CVE– 2023– 3446	OpenSSL	Issue summary: Checking excessively long DH keys or parameters may be very slow.	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2023– 3817	OpenSSL	Issue summary: Checking excessively long DH keys or parameters may be very slow. Advisory/fix: After fixing a related CVE it was discovered that a large q parameter value can also trigger an overly.	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2023– 5363	OpenSSL	Issue summary: A bug has been identified in the processing of key and initialisation vector (IV) lengths.	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2023– 5678	OpenSSL	Issue summary: Generating excessively long X9.42 DH keys or checking excessively long X9.42 DH keys or parameters may be very slow.	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2023– 6237	OpenSSL	Issue summary: Checking excessively long invalid RSA public keys may take a long time.	Concrete memory, parser, serialized object, resource, or application API semantics

CVE	Source	Description / patch basis	Missing model feature
			outside core TLS.
CVE– 2024– 0727	OpenSSL	Issue summary: Processing a maliciously formatted PKCS12 file may lead OpenSSL to crash leading to a potential Denial of Service attack Impact summary: Applications. Advisory/fix: We have also fixed a similar issue in SMIME_write_PKCS7().	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2024– 4603	OpenSSL	Issue summary: Checking excessively long DSA keys or parameters may be very slow.	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2024– 9143	OpenSSL	Issue summary: Use of the low-level GF(2 ^m) elliptic curve APIs with untrusted explicit values for the field polynomial can lead to out-of-bounds memory reads or.	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2025– 7394	wolfSSL	In the OpenSSL compatibility layer implementation, the function RAND_poll() was not behaving as expected and leading to the potential for predictable values.	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2025– 9230	OpenSSL	Issue summary: An application trying to decrypt CMS messages encrypted using password based encryption can trigger an out-of-bounds read and write.	Concrete memory, parser, serialized object, resource, or application API semantics

CVE	Source	Description / patch basis	Missing model feature
			outside core TLS.
CVE– 2025– 9232	OpenSSL	Issue summary: An application using the OpenSSL HTTP client API functions may trigger an out-of-bounds read if the 'no_proxy' environment variable is set and the.	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2025– 9820	GnuTLS	Severity Low; Stack write buffer overflow When a PKCS#11 token is initialized with gnutls_pkcs11_token_init function and it is passed a token label longer than.	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2025– 11187	OpenSSL	Issue summary: PBMAC1 parameters in PKCS#12 files are missing validation which can trigger a stack-based buffer overflow, invalid pointer or NULL pointer. Advisory/fix: If the value of keylength exceeds the size of the fixed stack buffer used for the derived key (64.	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2025– 11931	wolfSSL	Integer Underflow Leads to Out-of-Bounds Access in XChaCha20-Poly1305 Decrypt.	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2025– 15467	OpenSSL	Issue summary: Parsing CMS AuthEnvelopedData or EnvelopedData message with maliciously crafted AEAD parameters can trigger a stack buffer overflow.	Concrete memory, parser, serialized object, resource, or application API semantics

CVE	Source	Description / patch basis	Missing model feature
			outside core TLS.
CVE– 2025– 15468	OpenSSL	Issue summary: If an application using the SSL_CIPHER_find() function in a QUIC protocol client or server receives an unknown cipher suite from the peer, a NULL.	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2025– 32990	GnuTLS	Severity Low; Heap write buffer overflow When the certtool program is invoked with a template file with a number of string pairs for a single keyword, a NULL. Advisory/fix: Recommendation: To address the issue found upgrade to GnuTLS 3.8.10 or later versions.	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2025– 68160	OpenSSL	Issue summary: Writing large, newline-free data into a BIO chain using the line-buffering filter where the next BIO performs short writes can trigger a heap-based.	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2025– 69418	OpenSSL	Issue summary: When using the low-level OCB API directly with AES-NI or other hardware-accelerated code paths, inputs whose length is not a multiple of 16 bytes can.	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2025– 69419	OpenSSL	Issue summary: Calling PKCS12_get_friendlyname() function on a maliciously crafted PKCS#12 file with a BMPString (UTF-16BE) friendly name containing non-ASCII BMP.	Concrete memory, parser, serialized object, resource, or application API semantics

CVE	Source	Description / patch basis	Missing model feature
			outside core TLS.
CVE– 2025– 69421	OpenSSL	Issue summary: Processing a malformed PKCS#12 file can trigger a NULL pointer dereference in the PKCS12_item_decrypt_d2i_ex() function.	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2026– 0819	wolfSSL	wolfSSL PKCS7 SignedData encoding OOB write (signed attributes).	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2026– 4159	wolfSSL	1-byte OOB heap read in wc_PKCS7_DecodeEnvelopedData via zero-length encrypted content.	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2026– 4395	wolfSSL	A heap buffer out of bounds write case existed in wolfSSL version 5.8.4 and earlier when importing an ECC key while built with KCAPI support. Advisory/fix: The fix implemented added a check on the raw pubkey length in wc_ecc_import_x963 before copying it to an.	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2026– 5295	wolfSSL	Stack buffer overflow in PKCS7 ORI (Other Recipient Info) OID processing.	Concrete memory, parser, serialized object, resource, or application API semantics

CVE	Source	Description / patch basis	Missing model feature
			outside core TLS.
CVE– 2026– 5392	wolfSSL	Heap out-of-bounds read in PKCS7 parsing.	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2026– 5479	wolfSSL	In wolfSSL's EVP layer, the ChaCha20-Poly1305 AEAD decryption path in wolfSSL_EVP_CipherFinal (and related EVP cipher finalization functions) fails to verify the.	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2026– 5500	wolfSSL	wolfSSL's <code>wc_PKCS7_DecodeAuthEnvelopedData()</code> does not properly sanitize the AES-GCM authentication tag length received and has no lower bounds check.	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2026– 22795	OpenSSL	Issue summary: An invalid or NULL pointer dereference can happen in an application processing a malformed PKCS#12 file.	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2026– 22796	OpenSSL	Issue summary: A type confusion vulnerability exists in the signature verification of signed PKCS#7 data where an ASN1_TYPE union member is accessed without first.	Concrete memory, parser, serialized object, resource, or application API semantics

CVE	Source	Description / patch basis	Missing model feature
			outside core TLS.
CVE– 2026– 28386	OpenSSL	OpenSSL description says CFB mode is not used by TLS/DTLS; issue is AES-CFB128 AVX-512/VAES over-read.	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2026– 28389	OpenSSL	Issue summary: During processing of a crafted CMS EnvelopedData message with KeyAgreeRecipientInfo a NULL pointer dereference can happen.	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2026– 28390	OpenSSL	Issue summary: During processing of a crafted CMS EnvelopedData message with KeyTransportRecipientInfo a NULL pointer dereference can happen.	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2026– 31790	OpenSSL	Issue summary: Applications using RSASVE key encapsulation to establish a secret encryption key can send contents of an uninitialized memory buffer to a malicious.	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2026– 34875	Mbed TLS	Mbed TLS advisory: psa_export_public_key for FFDH can overflow caller output buffer.	Concrete memory, parser, serialized object, resource, or application API semantics

CVE	Source	Description / patch basis	Missing model feature
			outside core TLS.
CVE– 2026– 34876	Mbed TLS	Mbed TLS advisory: multipart CCM API misses tag_len validation, causing context overread.	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2026– 42014	GnuTLS	Severity Medium; use-after-free Changing the Security Officer PIN with gnutls_pkcs11_token_set_pin() with oldpin == NULL for a token lacking a protected. Advisory/fix: Recommendation: To address the issue found, upgrade to GnuTLS 3.8.13 or later versions.	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.
CVE– 2026– 42015	GnuTLS	Severity Low; out-of-bounds write Appending to a PKCS#12 bag that already contained 32 elements could write past the bag's internal array. Advisory/fix: Recommendation: To address the issue found, upgrade to GnuTLS 3.8.13 or later versions.	Concrete memory, parser, serialized object, resource, or application API semantics outside core TLS.

Category2.6 Timing/side-channel

CVE	Source	Description / patch basis	Missing model feature
CVE– 2016– 0702	OpenSSL	A side-channel attack was found which makes use of cache-bank conflicts on the Intel Sandy-Bridge microarchitecture which could lead to the recovery of RSA keys.	Timing, side-channel, padding-oracle, hardware/cache, or fault-observation semantics outside core TLS.
CVE– 2016– 0703	OpenSSL	This issue only affected versions of OpenSSL prior to March 19th 2015 at which time the code was refactored to address vulnerability a related CVE.	Timing, side-channel, padding-oracle, hardware/cache, or fault-observation

CVE	Source	Description / patch basis	Missing model feature
			semantics outside core TLS.
CVE-2016-0704	OpenSSL	This issue only affected versions of OpenSSL prior to March 19th 2015 at which time the code was refactored to address the vulnerability a related CVE.	Timing, side-channel, padding-oracle, hardware/cache, or fault-observation semantics outside core TLS.
CVE-2016-0800	OpenSSL	A cross-protocol attack was discovered that could lead to decryption of TLS sessions by using a server supporting SSLv2 and EXPORT cipher suites as a Bleichenbacher. Advisory/fix: Disabling all SSLv2 ciphers is also sufficient, provided the patches for a related CVE (fixed in OpenSSL.	Timing, side-channel, padding-oracle, hardware/cache, or fault-observation semantics outside core TLS.
CVE-2016-2178	OpenSSL	Operations in the DSA signing algorithm should run in constant time in order to avoid side channel attacks.	Timing, side-channel, padding-oracle, hardware/cache, or fault-observation semantics outside core TLS.
CVE-2016-7438	wolfSSL	Software ECC does not properly consider cache-bank monitoring	Timing, side-channel, padding-oracle, hardware/cache, or fault-observation semantics outside core TLS.
CVE-2016-7439	wolfSSL	Software RSA does not properly consider cache-bank monitoring	Timing, side-channel, padding-oracle, hardware/cache, or fault-observation semantics outside core TLS.
CVE-2016-7440	wolfSSL	Software AES table lookups do not properly consider cache-bank access times	Timing, side-channel, padding-oracle, hardware/cache, or fault-observation semantics outside core TLS.
CVE-2017-6076	wolfSSL	In versions of wolfSSL before 3.10.2 the software implementation makes it easier to extract RSA key	Timing, side-channel, padding-oracle, hardware/cache, or

CVE	Source	Description / patch basis	Missing model feature
		information for a malicious user who has access to view the.	fault-observation semantics outside core TLS.
CVE– 2018– 0734	OpenSSL	The OpenSSL DSA signature algorithm has been shown to be vulnerable to a timing side channel attack.	Timing, side-channel, padding-oracle, hardware/cache, or fault-observation semantics outside core TLS.
CVE– 2018– 0735	OpenSSL	The OpenSSL ECDSA signature algorithm has been shown to be vulnerable to a timing side channel attack.	Timing, side-channel, padding-oracle, hardware/cache, or fault-observation semantics outside core TLS.
CVE– 2018– 0737	OpenSSL	The OpenSSL RSA Key generation algorithm has been shown to be vulnerable to a cache timing side channel attack.	Timing, side-channel, padding-oracle, hardware/cache, or fault-observation semantics outside core TLS.
CVE– 2018– 5407	OpenSSL	OpenSSL ECC scalar multiplication, used in e.g.	Timing, side-channel, padding-oracle, hardware/cache, or fault-observation semantics outside core TLS.
CVE– 2018– 12436	wolfSSL	Versions of wolfSSL up to and including 3.15.0 are vulnerable to a Key Extraction Side Channel Attack.	Timing, side-channel, padding-oracle, hardware/cache, or fault-observation semantics outside core TLS.
CVE– 2019– 1547	OpenSSL	Normally in OpenSSL EC groups always have a co-factor present and this is used in side channel resistant code paths.	Timing, side-channel, padding-oracle, hardware/cache, or fault-observation semantics outside core TLS.
CVE– 2019–	OpenSSL	In situations where an attacker receives automated notification of the success or failure of a	Timing, side-channel, padding-oracle,

CVE	Source	Description / patch basis	Missing model feature
1563		decryption attempt an attacker, after sending a very large number of.	hardware/cache, or fault-observation semantics outside core TLS.
CVE– 2019– 13628	wolfSSL	Versions of wolfSSL before 4.1.0 are vulnerable to the potential leak of nonce sizes when performing ECDSA signing operations.	Timing, side-channel, padding-oracle, hardware/cache, or fault-observation semantics outside core TLS.
CVE– 2020– 11713	wolfSSL	wolfSSL versions prior to 4.4.0 have mulmod code in wc_ecc_mulmod_ex in ecc.c that does not properly resist timing side-channel attacks. Advisory/fix: Version 4.4.0 fixes this to be constant time and cache resistant.	Timing, side-channel, padding-oracle, hardware/cache, or fault-observation semantics outside core TLS.
CVE– 2020– 11735	wolfSSL	wolfSSL versions prior to 4.4.0 using fast math do not use a constant-time modular inverse when mapping to affine coordinates.	Timing, side-channel, padding-oracle, hardware/cache, or fault-observation semantics outside core TLS.
CVE– 2020– 12966	wolfSSL	Public disclosure of a side channel vulnerability that has been fixed since wolfSSL version 5.1.0.	Timing, side-channel, padding-oracle, hardware/cache, or fault-observation semantics outside core TLS.
CVE– 2020– 15309	wolfSSL	wolfSSL versions prior to 4.5.0 included a potential cache timing attack on public key operations in builds that are not using SP (single precision).	Timing, side-channel, padding-oracle, hardware/cache, or fault-observation semantics outside core TLS.
CVE– 2021– 24116	wolfSSL	Side-Channel cache look up vulnerability in base64 PEM decoding for versions of wolfSSL 4.5.0 and earlier. Advisory/fix: Versions 4.6.0 and up contain a fix and do not need to be updated for this report.	Timing, side-channel, padding-oracle, hardware/cache, or fault-observation semantics outside core TLS.

CVE	Source	Description / patch basis	Missing model feature
CVE-2021-46744	wolfSSL	Public disclosure of a side channel vulnerability that has been fixed since wolfSSL version 5.1.0.	Timing, side-channel, padding-oracle, hardware/cache, or fault-observation semantics outside core TLS.
CVE-2023-5981	GnuTLS	Severity Medium; more timing sidechannel in RSA-PSK key exchange The previous fix for this CVE turned to be incomplete as it still leaves an observable. Advisory/fix: Recommendation: To address the issue found upgrade to GnuTLS 3.8.3 or later versions.	Timing, side-channel, padding-oracle, hardware/cache, or fault-observation semantics outside core TLS.
CVE-2024-0553	GnuTLS	Severity Medium; more timing sidechannel in RSA-PSK key exchange The previous fix for a related CVE turned to be incomplete as it still leaves an observable. Advisory/fix: Recommendation: To address the issue found upgrade to GnuTLS 3.8.3 or later versions.	Timing, side-channel, padding-oracle, hardware/cache, or fault-observation semantics outside core TLS.
CVE-2024-1543	wolfSSL	A side channel vulnerability with AES T-Tables is possible in a very controlled environment where precision sub-cache-line inspection can happen, such as inside an. Advisory/fix: The fix for this issue is located in the following GitHub Pull Request.	Timing, side-channel, padding-oracle, hardware/cache, or fault-observation semantics outside core TLS.
CVE-2024-1544	wolfSSL	Potential ECDSA nonce side channel attack in versions of wolfSSL before 5.6.6 with wc_ecc_sign_hash calls. Advisory/fix: Fixed #7020	Timing, side-channel, padding-oracle, hardware/cache, or fault-observation semantics outside core TLS.
CVE-2024-28834	GnuTLS	Severity Medium; timing sidechannel in deterministic ECDSA A vulnerability was found that the deterministic ECDSA code leaks bit-length of random nonce which. Advisory/fix: Recommendation: To address the issue found upgrade to GnuTLS 3.8.4 or later versions.	Timing, side-channel, padding-oracle, hardware/cache, or fault-observation semantics outside core TLS.

CVE	Source	Description / patch basis	Missing model feature
CVE-2025-7396	wolfSSL	In wolfSSL 5.8.0 the option of hardening the C implementation of Curve25519 private key operations was added with the addition of blinding support.	Timing, side-channel, padding-oracle, hardware/cache, or fault-observation semantics outside core TLS.
CVE-2025-9231	OpenSSL	Issue summary: A timing side-channel which could potentially allow remote recovery of the private key exists in the SM2 algorithm implementation on 64 bit ARM.	Timing, side-channel, padding-oracle, hardware/cache, or fault-observation semantics outside core TLS.
CVE-2025-12888	wolfSSL	Vulnerability in X25519 constant-time cryptographic implementations due to timing side channels introduced by compiler optimizations and CPU architecture.	Timing, side-channel, padding-oracle, hardware/cache, or fault-observation semantics outside core TLS.
CVE-2025-54764	Mbed TLS	Mbed TLS advisory: RSA keygen/import/sign/decrypt side channel in modular inversion/GCD routines.	Timing, side-channel, padding-oracle, hardware/cache, or fault-observation semantics outside core TLS.
CVE-2025-59438	Mbed TLS	Mbed TLS advisory: CBC-PKCS7 padding oracle through non-constant-time API/error behavior.	Timing, side-channel, padding-oracle, hardware/cache, or fault-observation semantics outside core TLS.
CVE-2025-66442	Mbed TLS	Mbed TLS advisory: compiler optimization can break constant-time padding checks in RSA/CBC/ECB decryption.	Timing, side-channel, padding-oracle, hardware/cache, or fault-observation semantics outside core TLS.

CVE	Source	Description / patch basis	Missing model feature
CVE-2026-3579	wolfSSL	wolfSSL 5.8.4 and earlier on RISC-V RV32I architectures lacks a constant-time software implementation for 64-bit multiplication.	Timing, side-channel, padding-oracle, hardware/cache, or fault-observation semantics outside core TLS.
CVE-2026-3580	wolfSSL	Compiler-induced timing leak in <code>sp_256_get_entry_256_9</code> on RISC-V.	Timing, side-channel, padding-oracle, hardware/cache, or fault-observation semantics outside core TLS.
CVE-2026-5419	GnuTLS	Severity Low; timing side-channel The PKCS#7 padding check performed during decryption was not constant-time, potentially leaking information about the padding. Advisory/fix: Recommendation: To address the issue found, upgrade to GnuTLS 3.8.13 or later versions.	Timing, side-channel, padding-oracle, hardware/cache, or fault-observation semantics outside core TLS.
CVE-2026-5504	wolfSSL	A padding oracle exists in wolfSSL's PKCS7 CBC decryption that could allow an attacker to recover plaintext through repeated decryption queries with modified.	Timing, side-channel, padding-oracle, hardware/cache, or fault-observation semantics outside core TLS.

Category2.7 Other implementation details

CVE	Source	Description / patch basis	Missing model feature
CVE-2016-7055	OpenSSL	There is a carry propagating bug in the Broadwell-specific Montgomery multiplication procedure that handles input lengths divisible by, but longer than 256 bits.	Implementation, OS, CLI, hardware, product, or primitive behavior outside RFC 5246/8446.
CVE-2017-8855	wolfSSL	In versions of wolfSSL before 3.11.0 there are cases where a malformed DH key is not rejected by the function <code>wc_DhAgree</code> .	Implementation, OS, CLI, hardware, product, or primitive behavior

CVE	Source	Description / patch basis	Missing model feature
			outside RFC 5246/8446.
CVE– 2018– 0733	OpenSSL	Because of an implementation bug the PA-RISC CRYPTO_memcmp function is effectively reduced to only comparing the least significant bit of each byte.	Implementation, OS, CLI, hardware, product, or primitive behavior outside RFC 5246/8446.
CVE– 2019– 1543	OpenSSL	ChaCha20-Poly1305 is an AEAD cipher, and requires a unique nonce input for every encryption operation.	Implementation, OS, CLI, hardware, product, or primitive behavior outside RFC 5246/8446.
CVE– 2019– 1549	OpenSSL	OpenSSL 1.1.1 introduced a rewritten random number generator (RNG).	Implementation, OS, CLI, hardware, product, or primitive behavior outside RFC 5246/8446.
CVE– 2019– 1552	OpenSSL	OpenSSL has internal defaults for a directory tree where it can find a configuration file as well as certificates used for verification in TLS. Advisory/fix: This directory is most commonly referred to as OPENSSLDIR, and is configurable with the -prefix /.	Implementation, OS, CLI, hardware, product, or primitive behavior outside RFC 5246/8446.
CVE– 2019– 14317	wolfSSL	Versions of wolfSSL before 4.2.0 are vulnerable to DSA operations involving an attack on recovering DSA private keys.	Implementation, OS, CLI, hardware, product, or primitive behavior outside RFC 5246/8446.
CVE– 2021– 23839	OpenSSL	OpenSSL 1.0.2 supports SSLv2. Advisory/fix: Premium support customers of OpenSSL 1.0.2 should upgrade to 1.0.2y.	Implementation, OS, CLI, hardware, product, or

CVE	Source	Description / patch basis	Missing model feature
			primitive behavior outside RFC 5246/8446.
CVE– 2022– 1292	OpenSSL	The c_rehash script does not properly sanitise shell metacharacters to prevent command injection.	Implementation, OS, CLI, hardware, product, or primitive behavior outside RFC 5246/8446.
CVE– 2022– 2068	OpenSSL	In addition to the c_rehash shell command injection identified in a related CVE, further circumstances where the c_rehash script does not properly sanitise shell.	Implementation, OS, CLI, hardware, product, or primitive behavior outside RFC 5246/8446.
CVE– 2022– 42961	wolfSSL	Fault injection attack on RAM via Rowhammer leads to ECDSA key disclosure.	Implementation, OS, CLI, hardware, product, or primitive behavior outside RFC 5246/8446.
CVE– 2024– 1545	wolfSSL	Fault Injection vulnerability in RsaPrivateDecryption function that potentially allows an attacker that has access to the same system with a victims process to. Advisory/fix: Thanks to Junkai Liang, Zhi Zhang, Xin Zhang, Qingni Shen for the report (Peking University, The.	Implementation, OS, CLI, hardware, product, or primitive behavior outside RFC 5246/8446.
CVE– 2024– 2873	wolfSSL	A properly crafted SSH client can bypass user authentication in the wolfSSH server code. Advisory/fix: The added fix filters the messages that are allowed during different operational states.	Implementation, OS, CLI, hardware, product, or primitive behavior outside RFC 5246/8446.
CVE– 2024– 2881	wolfSSL	Fault injection attack with EdDSA signature operations. Advisory/fix: Fixed in this GitHub pull request #7212	Implementation, OS, CLI, hardware,

CVE	Source	Description / patch basis	Missing model feature
			product, or primitive behavior outside RFC 5246/8446.
CVE– 2024– 5288	wolfSSL	A private key blinding operation, enabled by defining the macro WOLFSSL_BLIND_PRIVATE_KEY, was added to mitigate a potential row hammer attack on ECC operations. Advisory/fix: Caner Tol, Berk Sunar for the report (Vernam Applied Cryptography and Cybersecurity Lab at Worcester.	Implementation, OS, CLI, hardware, product, or primitive behavior outside RFC 5246/8446.
CVE– 2025– 15469	OpenSSL	Issue summary: The 'openssl dgst' command-line tool silently truncates input data to 16MB when using one-shot signing algorithms and reports success instead of an.	Implementation, OS, CLI, hardware, product, or primitive behavior outside RFC 5246/8446.
CVE– 2026– 0930	wolfSSL	Potential read out of bounds case with wolfSSHd on Windows while handling a terminal resize request.	Implementation, OS, CLI, hardware, product, or primitive behavior outside RFC 5246/8446.
CVE– 2026– 3503	wolfSSL	A protection mechanism failure in wolfCrypt post-quantum implementations (ML-KEM and ML-DSA) in wolfSSL on ARM Cortex-M microcontrollers allows a physical attacker. Advisory/fix: This issue affects wolfSSL (wolfCrypt): commit hash d86575c766e6e67ef93545fa69c04d6eb49400c6.	Implementation, OS, CLI, hardware, product, or primitive behavior outside RFC 5246/8446.
CVE– 2026– 5466	wolfSSL	wolfSSL's ECCSI signature verifier <code>wc_VerifyEccsiHash</code> decodes the <code>r</code> and <code>s</code> scalars from the signature blob via <code>mp_read_unsigned_bin</code> with no check that they.	Implementation, OS, CLI, hardware, product, or primitive behavior outside RFC 5246/8446.
CVE– 2026–	wolfSSL	Potential for AES-EAX AEAD and CMAC authentication bypass on messages larger than 4 GiB.	Implementation, OS, CLI,

CVE	Source	Description / patch basis	Missing model feature
5477			hardware, product, or primitive behavior outside RFC 5246/8446.
CVE–2026–25835	Mbed TLS	Mbed TLS advisory: PSA random generator state can be cloned across fork, VM, or image cloning.	Implementation, OS, CLI, hardware, product, or primitive behavior outside RFC 5246/8446.
CVE–2026–34871	Mbed TLS	Mbed TLS advisory: Linux entropy source can fall back to /dev/urandom before sufficient entropy.	Implementation, OS, CLI, hardware, product, or primitive behavior outside RFC 5246/8446.
CVE–2026–34872	Mbed TLS	Official Mbed TLS advisory says TLS 1.2 and TLS 1.3 are not affected; issue is PSA FFDH peer-key validation.	PSA FFDH validation and contributory-behavior checks outside stream TLS.

Notes On Reclassified Edge Cases

- The old DTLS bucket contained one OpenSSL DH unsafe-prime/static-exponent issue; it is now in Category1.2.
- Two OpenSSL low-level cipher API issues were moved out of DTLS because the descriptions state that the affected modes are not used by TLS/DTLS.
- One Mbed TLS FFDH validation issue was moved out of RFC5246/8446 scope because the advisory says TLS 1.2 and TLS 1.3 are not affected.
- A paired GnuTLS local description was split using CVE/advisory context: one issue is certificate verification object lifetime, and the other is TLS 1.3 post-handshake/asynchronous message pointer state.
- The GnuTLS RSA-PSK embedded-NUL username issue is Category2.3 because the issue is external RSA-PSK identity/provisioning equality, not a modeled RFC 8446 resumption PSK binder case.